



BÁO CÁO REDTEAM

Môn học: An toàn mạng

GVHD: TS. Lê Kim Hùng

Lớp: NT213.Q11.ANTT

Nhóm: 3

THÀNH VIÊN THỰC HIỆN:

STT	Họ và tên	MSSV
1	Phạm Lê Đăng Kha	23520669
2	Trần Việt Hoàng	23520543

Phần bên dưới của báo cáo này là báo cáo chi tiết của nhóm thực hiện

MỤC LỤC

A.	Các phát hiện từ quá trình trình sát và các lỗ hổng đã xác định.....	3
1.	Tấn công từ bên ngoài.....	3
a.	Kết quả trình sát.....	3
b.	Các lỗ hổng Web và WAF.....	3
2.	Tấn công từ bên trong.....	3
a.	Tấn công từ LAN 30.....	4
b.	Tấn công từ LAN 10.....	4
B.	Phân tích về hệ thống phòng thủ của Blue Team	5
1.	Tổng quan.....	5
a.	Trước khi ứng phó sự cố.....	5
b.	Sau khi ứng phó sự cố.....	5
2.	Chi tiết.....	5
a.	Trước khi ứng phó sự cố.....	5
b.	Sau khi ứng phó sự cố.....	6
C.	Các khuyến nghị khắc phục	7

A. Các phát hiện từ quá trình trinh sát và các lỗ hổng đã xác định

1. Tấn công từ bên ngoài

Mục tiêu: IP WAN của pfSense + Reverse Proxy (Nginx) + Web Server

a. Kết quả trinh sát

Host Discovery

- ICMP bị chặn hoàn toàn (100% packet loss)
- TCP SYN Ping: Vượt qua Firewall nhưng mà nếu gửi nhiều vẫn bị chặn

Services & Port Scanning

- Chỉ có port 80 (HTTP) mở.
- Có dịch vụ Nginx làm Reverse Proxy.
- Xác định web có WAF chặn ở trước và có IPS chặn (sử dụng các kỹ thuật khai thác lỗ hổng web thì nhận về status code 403, sử dụng quét bằng nmap hoặc nuclei thì bị đứng giữa chừng)

b. Các lỗ hổng Web và WAF

Hầu hết các kỹ thuật tấn công web phổ biến đều bị chặn bởi hệ thống của bên blue team:

- SQL Injection: Thất bại
- XSS: Thất bại
- Path Traversal: Thất bại
- Command Injection: Thất bại
- Directory Fuzzing: Tìm thấy thư mục **actuator** của springboot. Đây là các endpoint quản trị của Spring Boot Framework bị lộ ra nhưng không có cơ chế xác thực. Có thể lộ biến môi trường, các secret keys, API token...

Lỗ hổng phát hiện:

- Springboot Actuator (thuộc loại Unauthenticated Access)
 - Mức độ nghiêm trọng: Cao
 - Tác động:
 - Lộ các thông tin như biến môi trường, các secret keys, tài khoản database, IP nội bộ...
 - Trong trường hợp có các thư viện jolokia hoặc h2 console, có thể dẫn đến RCE.
 - Từ các thông tin bị lộ này, attacker có thể tìm hiểu được sơ đồ mạng nội bộ, thông tin để tiếp tục khai thác nhằm chiếm được shell của máy chủ WebServer.

2. Tấn công từ bên trong

Ngữ cảnh: Có 2 ngữ cảnh chính

- Hacker chiếm được shell của WebServer với quyền user bình thường (LAN 10)
- Tấn công từ LAN 30 (có thể là kẻ tấn công là nhân viên, máy tính nhân viên bị xâm nhập,...)

a. Tấn công từ LAN 30

Kết quả quá trình trinh sát nội bộ

ICMP bị chặn hoàn toàn (100% packet loss)

Có 3 port được mở là 445 để kết nối đến File Server qua giao thức SMB và 1514, 1515 cho wazuh agent.

Xác định được IP Gateway là 192.168.40.1 và File Server là 192.168.30.10

Có dịch vụ SMB đang chạy phiên bản 4.6.2 (có CVE-2017-7494)

Các lỗ hổng đã phát hiện

- File Server phân quyền cho phép người dùng thông thường có quyền ghi và thực thi file trên thư mục chia sẻ chung.
 - Mức độ nghiêm trọng: Trung bình - cao
 - Tác động:
 - Tạo tiền đề để thực hiện CVE-2017-7494
 - Mất tính toàn vẹn và bảo mật của data-at-rest.
 - Nguy cơ lây nhiễm ransomware/mã độc (mất tính availability của data-at-rest) trong mạng nội bộ.
- Máy tính employee không kiểm soát và thay đổi mật khẩu của user root (cho phép tải bất kỳ cái gì mà nhân viên mong muốn để khai thác trên đó). (lỗ hổng từ chính sách bảo mật trước lần cập nhật cuối cùng)
- CVE-2017-7494: File Server sử dụng phiên bản Samba có CVE (SambaCry) có thể dẫn đến RCE (máy employee lấy được shell có quyền root trên File Server)
 - Mức độ nghiêm trọng: Nghiêm trọng
 - Tác động:
 - Attacker từ LAN30 chiếm được quyền root trên File Server.
 - Mất hoàn toàn tính bảo mật, toàn vẹn và khả dụng của 3 trạng thái data.

b. Tấn công từ LAN 10

Kết quả quá trình trinh sát nội bộ

ICMP bị chặn hoàn toàn (100% packet loss)

WebServer không có kết nối mạng

WebServer bị cô lập hoàn toàn, chỉ có kết nối đến Reverse proxy.

Các lỗ hổng đã phát hiện

- Chỉ với quyền user bình thường có quyền thực thi docker, ta có thể Privilege Escalation lên thành shell với quyền root.
 - Mức độ nghiêm trọng: Trung bình - cao
 - Tác động: từ một người dùng bình thường chiếm được root của WebServer.

B. Phân tích về hệ thống phòng thủ của Blue Team

1. Tổng quan

a. Trước khi ứng phó sự cố

Mô hình bảo mật của Blue team thiên nhiều về bảo vệ biên mà không chú ý vào các lỗ hổng ở trong môi trường mạng nội bộ.

- Có WAF, IPS, Firewall được cấu hình tốt, hiệu quả tốt khi chặn được hầu hết các cuộc tấn công đơn giản và quét bằng các tool.
- Phân quyền người dùng sai nguyên tắc, chính sách bảo mật còn lỗ hổng, sử dụng các phiên bản dịch vụ có lỗ hổng.

b. Sau khi ứng phó sự cố

Mô hình bảo mật của Blue team đã được chuyển sang thành Defense-in-depth, hầu như đã vá được tất cả các lỗ hổng đang hiện hữu.

- Đã thu hồi quyền root trên máy employee, quyền docker trên máy WebServer, ẩn các endpoint nhạy cảm.
- Nâng cấp phiên bản Samba và chỉnh lại quyền của user ở trên thư mục share ở trên FileServer.

2. Chi tiết

a. Trước khi ứng phó sự cố

Lớp bảo vệ biên

Đánh giá: Tốt

Điểm mạnh:

- Firewall & IDS: Cấu hình chặn ICMP rất tốt, không phát hiện được port nào khác port dành cho kết nối HTTP, khi có dấu hiệu gửi nhiều gói tin đến thì chặn ngay IP đó. Chặn các IP của của giả lập DDoS khá nhanh.
- WAF & Reverse Proxy: Triển khai ModSecurity nhưng mà khi sử dụng các kỹ thuật để nhận diện đây là WAF gì thì hầu như không thấy fingerprint nào của ModSecurity hết. WAF hoạt động tốt khi chặn được hầu hết các kỹ thuật tấn công web phổ biến từ OWASP Top 10. Sử dụng reverse proxy giúp giấu thông tin backend, hạn chế bị lộ thông tin nội bộ.

Điểm yếu:

- Để lộ endpoint quản trị của web (/actuator) khi sử dụng reverse proxy là một lỗ hổng khá nghiêm trọng.

Lớp bảo vệ nội bộ

Đánh giá: Yếu

Điểm mạnh:

- Phân vùng mạng khá tốt, có sự chia tách giữa mạng của các máy employee và các mạng của server.
- WebServer được cô lập hoàn toàn, không kết nối được đến các máy khác trong mạng nội bộ và cũng không có kết nối internet, chỉ có 1 đường kết nối là Reverse proxy ở DMZ zone.

Điểm yếu:

- Mặc dù đã có Wazuh Agent trên hầu hết tất cả các máy nhưng các hành vi bất thường như tải các file .so qua samba lên FileServer hay sử dụng docker để Privilege Escalation thì dường như không phát hiện hoặc ngăn chặn kịp thời. Cho thấy hệ thống phòng thủ chưa đủ sâu, chi tiết cho các vấn đề ở trong các dịch vụ trong mạng.

Lớp An toàn máy chủ & Ứng dụng

Đánh giá: Rất yếu

- Sử dụng phiên bản Samba phiên bản 4.6.2 từ năm 2017 với lỗi CVE nghiêm trọng.
- FileServer: Cho phép user bình thường có quyền ghi và thực thi vào thư mục share.
- WebServer: gán user thường vào group docker. Từ đó mới bị Privilege Escalation
- Employee Workstation: Người dùng có quyền root nội bộ, vi phạm quy tắc bảo mật cơ bản, giúp cho insider threat có thể dễ dàng tấn công hệ thống nội bộ.

b. Sau khi ứng phó sự cố

Sau khi phát hiện các lỗ hổng từ các đợt tấn công của Red Team, Blue Team đã thực hiện một số biện pháp để khắc phục các lỗ hổng đã được tìm thấy, chuyển mô hình hệ thống trọng tâm ở bảo vệ biên thành phòng thủ theo chiều sâu và zero-trust khi các máy tính nhân viên cũng phải qua các bước xác minh gắt gao mới vào được hệ thống mạng.

Web Server:

- Ẩn các endpoint nhạy cảm.
- Tài khoản user thường đã bị gỡ khỏi nhóm docker. Hiện tại thì quản trị Docker sẽ cần quyền sudo rõ ràng.

File Server:

- Blue Team đã thay đổi cấu hình của Samba để yêu cầu các máy tính của nhân viên phải có tài khoản người dùng hợp lệ mới có thể truy cập vào thư mục chia sẻ chung, giúp giảm thiểu rủi ro khi một máy tính của nhân viên bị kẻ tấn công xâm nhập.
- Ta không còn được tải các file có đuôi lạ lên thư mục chia sẻ chung của File Server nữa.

- Phiên bản Samba cũng đã được cập nhật lên phiên bản mới nhất, không còn các lỗ hổng bảo mật.

Chính sách bảo mật cũng đã được cập nhật đầy đủ về quyền hạn của người dùng cuối, cho thấy được sự an toàn chặt chẽ trong cả hệ thống lẫn chính sách bảo mật.

Đánh giá hệ thống phòng thủ của Blue Team sau khi khắc phục sự cố: Rất tốt <3

C. Các khuyến nghị khắc phục

Web Server:

- Khuyến nghị cấu hình **Spring Security** trực tiếp trong mã nguồn ứng dụng để yêu cầu xác thực và phân quyền cho mọi truy cập vào /actuator/*. Để tránh trường hợp kẻ tấn công vượt qua được proxy (vd: tấn công từ nội bộ LAN 10), endpoint này có thể vẫn bị lộ.
- Red Team khuyến nghị docker nên chuyển sang chế độ Rootless Docker (chạy Docker daemon hoàn toàn không cần quyền root) sẽ loại bỏ hoàn toàn nguy cơ leo thang đặc quyền.

Mạng nội bộ:

- Sử dụng 2 rule của firewall sau đối với các vùng mạng chứa các máy chủ quan trọng theo thứ tự từ trên xuống:
 - Chặn chiều ra Internet của các máy chủ quan trọng (File Server, Web Server, SIEM)
 - Cho phép chiều ra Internet của các máy chủ quan trọng.
- Khi sử dụng 2 rule như này, sẽ linh hoạt hơn cho admin khi cần update hệ thống, phiên bản của webapp, các dịch vụ và lưu ý là luôn luôn để rule chặn chiều ra Internet trên rule cho phép chiều ra Internet.

Tự động hoá quy trình giám sát

- Cấu hình Wazuh để tự động phát hiện và cảnh báo quản trị viên khi có sự thay đổi trong các file cấu hình quan trọng trong các máy tính nhân viên, các máy chủ quan trọng trong mạng nội bộ để chống lại việc thay đổi cấu hình trái phép.
- Thiết lập quy trình cập nhật bản vá tự động cho các dịch vụ quan trọng (Samba, Docker, Nginx) để tránh lặp lại sự cố sử dụng phần mềm lỗi thời (Samba v4.6.2).